Secure Cloud Computing: 7 Ways I'd Hack You On AWS

AMAZON WEB SERVICES

Table of Contents

- Check your Cloud Settings
- Hack 1: The Little Phish: The Password is Catch of the Day
- Hack 2: The Big Phish: You've Been Speared
- Hack 3: Passwords, Passwords, Everywhere Does Not Help Secure Cloud Computing
- Hack 4: The Keys to the Kingdom
- Hack 5: Oops, GitHub Exposure
- Hack 6: Where's Waldo?
- Hack 7: Advanced Attack? Nuke from Orbit
- The Best Defense is a Good Offense
- Get Expert Cybersecurity Help
- Talk to us!
- Do you think we might be a good match?

If you're like most businesses, you're thinking about moving to the cloud but you're worried about secure cloud computing. Lower costs, more control, and greater resiliency are all powerful motivators. But the loss of control of your environment is awfully scary.

A move to the cloud presents new security challenges. There are new tools to learn and new controls to put in place. It's no longer enough to simply throw up a firewall and hope for the best.

Amazon Web Services (AWS) is definitely the best-known cloud hosting platform. We thought it would be fun to do a little thought experiment.

If we were hackers going after your data in AWS, how would we try to get it?

We came up with seven likely attacks. Below, we'll tell you how we'd get in. We'll also walk you through what you should do to keep us out.

Check your Cloud Settings

Before we get into our hacking thought experiment, we wanted to give some advice.

Cloud programs like AWS, Google Workspace, Microsoft 365, WordPress, and the like are all great programs, and many of our clients use them. But they are not secure right out of the box.

Do you know what settings to change and why? Does your IT company know what settings to change and why?

The article below has plenty of tips that apply to any cloud service. But it's safer and wiser to have a reputable company review these settings for you. That's where we come in – our Virtual CISO service includes annual cloud audits (https://adeliarisk.com/virtual-ciso-service/) of your major cloud systems and so much more.

If you need help with security compliance, protecting revenue, passing audits, or managing IT, we can help. We typically work with clients in highly regulated industries like healthcare, financial services and government contracting, and we can help you too!

Hack 1: The Little Phish: The Password is Catch of the Day

Phishing (/8-phishing-facts-9-phishing-tips/) is still unbelievably popular with cyber criminals.

Why? It works.

According to the Verizon Data Breach Investigation Report (DBIR), 30% of people opened phishing messages in 2016. Almost one-third of people open phishing messages!

If I were trying to get your AWS credentials, I'd send you a cleverly worded email or SMS with a malicious link in it.

The link would take you to what LOOKS like the AWS login page. Instead, it would steal your credentials.

The Fix to Achieve Secure Cloud Computing:

Your best defense? Turn on two-factor authentication (2FA) (http://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_mfa.html). If your AWS login requires a second factor, then even if a user does click on a phishing link they won't be able to log in.

Here's how 2FA works. When you log in, you also need to enter a six-digit code. You get the code either through text message or an app you download.

Once you have 2FA in place, you limit the damage a hacker can do. Even if they have your username and password, they won't get any further. You stop the hacker in their tracks.

It's also a good idea to train anyone with AWS access never to log in to a page where they don't go there directly. Unfortunately, training isn't a strong security measure. That's why you should offer training AND turn on two-factor authentication.

Hack 2: The Big Phish: You've Been Speared

Spear phishing goes one step further than general phishing emails. Spear phishing gets under your skin by using social engineering tactics to hook you and reel you in.

A spear phisher will take time to find out all they can about you and your company. They generally target executives or administrators who have high levels of access.

The SANS Institute (https://www.information-age.com/top-ten-things-you-need-know-about-data-breaches-123460135/) estimates 95% of major recent breaches started with a spear phishing email. The massive Target breach of 2014 led to the breach of 110 million customer accounts. You guessed it – it started with a spear phishing attack against Target's HVAC vendor.

The Fix to Achieve Secure Cloud Computing:

Having root access is like having the keys to the kingdom. Never, ever use root access for everyday jobs, not even administration level tasks.

Instead, you should create separate accounts (http://docs.aws.amazon.com/general/latest/gr/root-vs-iam.html) with the proper privileges. You should only use the root to start off your account management process to set up users.

Root Account Credentials vs. IAM User Credentials

All AWS accounts have root account credentials. These credentials allow full access to all resources in the account. Because you can't control the privileges of the root account credentials, you should store them in a safe place and instead use AWS Identity and Access Management (IAM) user credentials for day-to-day interaction with AWS.

With IAM, you can securely control access to AWS services and resources for users in your AWS account. For example, if you require administrator-level permissions, you can create an IAM user, grant that user full access, and then use those credentials to interact with AWS. Later, if you need to revoke or modify your permissions, you can delete or modify any policies that are associated with that IAM user.

Some companies only use the root account for billing on AWS. It's even better to move billing to a dedicated amount. That way, the only thing you'll use "root" for is resetting accounts.

It's also a good idea at this point, to change the root password to something long and complicated.

If you forget it, that's OK as you can use the password reset feature next time you have to use the root account. But make sure you have two-factor authentication set up on root! If you don't, your email account becomes the weakest link in the attack chain.

Hack 3: Passwords, Passwords, Everywhere Does Not Help Secure Cloud Computing

Tons of people use the same password across multiple sites. Research has shown that around 55% of adults use the same password across multiple sites. Yikes!

This is a terrible idea. You're trusting that every site will keep your password safe.

If they're hacked (like LinkedIn (http://www.theregister.co.uk/2016/05/24/linkedin_password_leak_hack_crack/)), cybercriminals will try to use these passwords on AWS.

The Fix to Achieve Secure Cloud Computing:

This one's easy. Use a UNIQUE password for your AWS account. Better yet, use a password manager (https://www.wired.com/2016/01/you-need-a-password-manager/) so you can get strong, unique passwords that are easy to remember.

Hack 4: The Keys to the Kingdom

AWS uses access keys (https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_access-keys.html) to allow technical users to control cloud servers. These are strings of data that let users get to their machines without a username or password.

These are literally the keys to your AWS kingdom. If someone gets these keys, they have full control of your AWS servers. Here's an example of what they look like:

5. To see your access key, choose **Show User Security Credentials**. Your credentials will look something like this:

- Access Key ID: AKIAIOSFODNN7EXAMPLE
- Secret Access Key: wJalrXUtnFEMI/K7MDENG/bPxRfiCYEXAMPLEKEY

The Fix to Achieve Secure Cloud Computing:

First, train your people on proper handling of keys. They should only be:

1. stored on encrypted machines to protect against loss or theft
2. NEVER sent via email
3. NEVER generate an access key for your root account
4. If possible, set an expiration date on your access keys
5. Rotate keys periodically, and remove unused keys regularly

Second, set up monitoring and alerts. Amazon offers a monitoring service called CloudWatch (https://aws.amazon.com/cloudwatch/). If an attacker starts using your AWS servers in an unusual manner, you'll get an alert and can check for a breach.

Third, set up specific AWS billing alerts (https://aws.amazon.com/about-aws/whats-new/2012/05/10/announcing-aws-billing-alerts/). I know it sounds weird — how can billing alerts help security? Well, when an attacker takes over your server, they might not just steal data. They might also use your server as part of an attack. They might repurpose it to be part of a botnet, or to send out spam messages. And if your server spins up, you'll be charged more.

Hack 5: Oops, GitHub Exposure

Developers accidentally upload their AWS access keys to sites like GitHub. Clever attackers are using bots to scan GitHub all the time to find unprotected AWS access keys.

This exact scenario happened to Andrew Hoffman, as reported in The Register (http://www.theregister.co.uk/2015/01/06/dev_blunder_shows_github_crawling_with_keyslurping_bots/). Andrew had published some code to GitHib for securing Ruby apps. He also published his AWS access keys at the same time, a major 'oops' moment. In his case, the cybercriminals had added 140 new servers to his account and used them to mine litecoins.

The Fix to Achieve Secure Cloud Computing:

Consider using temporary access keys in their best practice for access keys guide. Also, never embed keys directly into code. Make it part of your code review process to look for directly embedded keys.

Also, have some strict policies and monitoring around sites like GitHub.

Hack 6: Where's Waldo?

There are a lot of ways that web services and applications can be attacked.

The OWASP top ten (https://www.owasp.org/index.php/OWASP_Top_Ten_Cheat_Sheet) give you guidance on the big web hacks of the moment. You need to be all over this if your web application handles sensitive PII or PHI. Hopefully, you already know that attackers are always scanning your sites. When they find a way in, they jump on it.

The Fix to Achieve Secure Cloud Computing:

AWS gives you a strong control to fight web application attacks. If you can, use IP whitelisting to limit access to your web applications. AWS makes it very easy to limit specific ports and traffic only from specific IP addresses.

This is all managed through a tool called "Security Groups." They're super easy to set up. You do need to be careful about monitoring and controlling them, though. It's easy for security groups to get out of control and allow unapproved access.

You can also use Amazon's relatively (https://aws.amazon.com/waf/)new Web Application Firewall to harden your web application and protect from SQL Injection and XSS attacks.

Here's an example of setting up a security group for a Linux server (http://docs.aws.amazon.com/AWSEC2/latest/UserGuide/using-network-security.html) — it's similar on Windows as well.

If only a few locations will be using your web app, it's even better to use the Amazon Virtual Private Cloud (https://aws.amazon.com/vpc/) (VPC).

Hack 7: Advanced Attack? Nuke from Orbit

If the worst happens and malware gets on to your servers, you can end up with a lot of lost data. This costs your company not only money, but reputation too.

Sometimes attacks are so sophisticated and so buried that they're nearly impossible to fix. The industry refers to this kind of targeted attack as an "Advanced Persistent Threat."

If you're in this situation, your goal is to get your business back online as quickly as possible. At the same time, you don't want to destroy any evidence that could help you find the attackers.

The Best Defense is a Good Offense

One of the best things about cloud computing is just how easy it is to create a solid, robust backup strategy. That way, if you're hacked, you always have a way to revert back to known good servers and data.

Services like AWS make it easy and affordable to create multiple backups. It's also easy to restore these backups on to new virtual servers. In a disaster, you can restore to a new server quickly and leave the infected servers untouched.

Different tiers of storage all work together to create a robust backup strategy. Services at AWS like EBS, S3, and Glacier balance speed and cost. If the $#!+ hits the fan, you have a fallback plan that won't kill your business.

Get Expert Cybersecurity Help

Cybersecurity services are not just for the 'big' companies.

Small and medium-sized businesses need cybersecurity help too. But it doesn't make sense to hire a full-time CISO.

That's where a Virtual CISO (or vCISO) comes in.